

**BỘ GIÁO DỤC VÀ ĐÀO TẠO
TRƯỜNG ĐẠI HỌC FPT**

**KIẾN TRÚC NHẬN THỨC HAI TẦNG CHO PHÁT HIỆN
VÀ PHẢN HỒI MỖI ĐE DỌA TỰ ĐỘNG SỬ DỤNG AI
TÁC TỬ (AGENTIC AI)**

thực hiện bởi

Nguyễn Đức Bình

Luận văn được nộp để đáp ứng yêu cầu
của học vị Thạc sĩ Kỹ thuật Phần mềm

**BỘ GIÁO DỤC VÀ ĐÀO TẠO
TRƯỜNG ĐẠI HỌC FPT**

**KIẾN TRÚC NHẬN THỨC HAI TẦNG CHO PHÁT HIỆN
VÀ PHẢN HỒI MỐI ĐE DỌA TỰ ĐỘNG SỬ DỤNG AI
TÁC TỬ (AGENTIC AI)**

thực hiện bởi

Nguyễn Đức Bình

Luận văn được nộp để đáp ứng yêu cầu
của học vị Thạc sĩ Kỹ thuật Phần mềm

Giảng viên hướng dẫn:

TS. Bùi Văn Hiệu

TS. Đặng Văn Hiếu

Tóm tắt

Trong bối cảnh an ninh mạng hiện đại, các Trung tâm Điều hành An ninh mạng (SOC) đứng trước áp lực phải tự động hóa quá trình phân loại và phản hồi một khối lượng cảnh báo ngày một gia tăng; thế nhưng mọi giải pháp sẵn có đều buộc phải chấp nhận những đánh đổi đáng kể. Các công cụ tự động hóa truyền thống vận hành theo những kịch bản cứng nhắc, định sẵn, không thể suy xét các tình huống mơ hồ và cũng không thể lý giải cho quyết định của mình; trong khi việc đưa trực tiếp nhật ký thô vào một Mô hình Ngôn ngữ Lớn (LLM) lại quá chậm để đáp ứng thời gian thực, dễ bị thao túng ngay từ chính nội dung nhật ký, và sẽ vi phạm yêu cầu về chủ quyền dữ liệu nếu triển khai trên nền tảng đám mây. Nhằm khắc phục những hạn chế đó, luận văn đề xuất SENTINEL, một kiến trúc nhận thức hai tầng cho phát hiện và phản hồi mối đe dọa tự động. Tầng thứ nhất là một bộ lọc nhanh, tắt định, loại bỏ tức thời phần lớn lưu lượng vô hại và chỉ chuyển tiếp phần thiểu số thực sự khả nghi lên tầng thứ hai, một tác tử trí tuệ nhân tạo vận hành cục bộ, suy luận trên các nguồn tri thức an ninh chuẩn mực (kỹ thuật MITRE ATT&CK và hướng dẫn ứng phó sự cố của NIST) và hoạt động phía sau nhiều lớp rào chắn bảo vệ nhằm chống lại sự đánh lừa từ những đầu vào độc hại.

Qua đánh giá trên các bộ dữ liệu phát hiện xâm nhập tiêu chuẩn, SENTINEL cho thấy khả năng duy trì tính khả thi thực tiễn của suy luận bằng trí tuệ nhân tạo: bằng cách chỉ dành năng lực tính toán đắt đỏ này cho số ít cảnh báo thực sự cần đến, hệ thống giảm hơn 80% độ trễ phản hồi trung bình so với phương án chỉ sử dụng LLM. Hệ thống đồng thời chống chịu được các tấn công thao túng dựa trên nội dung, đưa ra những lý giải minh bạch và có thể kiểm chứng cho mỗi quyết định, và vận hành trọn vẹn trên phần cứng phổ thông tại chỗ mà không cần gửi dữ liệu ra bên ngoài. Nhìn chung, nghiên cứu khẳng định rằng sự kết hợp giữa một bộ lọc tắt định tốc độ cao và một tầng suy luận trí tuệ nhân tạo an toàn, minh bạch, triển khai cục bộ chính là một hướng tiếp cận thiết thực và đáng tin cậy cho bài toán tự động hóa phòng thủ mạng hiện đại.

Lời cảm ơn

Trước hết, tôi xin bày tỏ lòng biết ơn chân thành và sâu sắc nhất tới hai người thầy hướng dẫn khoa học của mình, TS. Bùi Văn Hiệu và TS. Đặng Văn Hiếu. Sự định hướng khoa học chuẩn xác, những góp ý chuyên môn sâu sắc cùng sự tận tâm và kiên nhẫn dịu dặt của quý thầy trong suốt chặng đường thực hiện đề tài chính là nền tảng vững chắc để tôi hoàn thành công trình nghiên cứu này một cách trọn vẹn.

Tôi cũng xin trân trọng gửi lời tri ân tới quý thầy cô và cán bộ của Viện Quản trị & Công nghệ FSB, Đại học FPT, những người đã trang bị cho tôi nền tảng tri thức học thuật quý báu và kiến tạo một môi trường học tập, nghiên cứu chuyên nghiệp, hiện đại, tạo mọi điều kiện thuận lợi cho học viên trong suốt quá trình theo học chương trình Thạc sĩ.

Đồng thời, tôi xin gửi lời cảm ơn sâu sắc tới Ban lãnh đạo cùng các đồng nghiệp tại Cục C12, Trung tâm Dữ liệu Quốc gia, nơi tôi đang công tác. Sự tạo điều kiện về thời gian, môi trường làm việc thực tiễn và những trao đổi chuyên môn quý giá đã tiếp thêm cho tôi nhiều động lực để hoàn thành tốt cả nhiệm vụ chuyên môn lẫn con đường học tập, nghiên cứu.

Cuối cùng, và cũng là điều thiêng liêng nhất, tôi xin dành trọn lòng tri ân tới gia đình thân yêu của mình, đặc biệt là người vợ hiền và con nhỏ. Sự hy sinh thầm lặng, lòng kiên nhẫn, sự thấu hiểu và nguồn động viên tinh thần không ngừng nghỉ của gia đình trong những tháng ngày tôi miệt mài với các đợt thực nghiệm kéo dài chính là điểm tựa lớn lao nhất, nâng bước tôi vững vàng trên hành trình chinh phục học vị Thạc sĩ.

Danh sách hình vẽ

Hình 1.	Kiến trúc tổng thể SENTINEL: luồng dữ liệu hai tầng và các cấu phần. (Nguồn: Tác giả)	12
Hình 2.	Luồng thực thi vận hành chi tiết trong pipeline SENTINEL. (Nguồn: Tác giả)	13

Danh sách bảng

Bảng 1.	Ma trận chuyển trạng thái của tác tử nhận thức Tầng 2. (Nguồn: Tác giả)	14
Bảng 2.	Các mô hình truy xuất trong chiến lược tìm kiếm lai (Dual-RAG). (Nguồn: Tác giả)	15
Bảng 3.	Lược đồ cơ sở dữ liệu Bộ nhớ Đe dọa. (Nguồn: Tác giả)	15
Bảng 4.	Phân loại nhị phân Tầng 1 (Luồng Gộp). (Nguồn: Tác giả)	16
Bảng 5.	Phân loại và giảm tải LLM của Cổng ML. (Nguồn: Tác giả)	16
Bảng 6.	Phán xử Tầng 2 trên sự kiện leo thang. (Nguồn: Tác giả)	17
Bảng 7.	Phát hiện APT đa giai đoạn nổi lên (DAPT2020). (Nguồn: Tác giả)	17
Bảng 8.	Đường biên phát hiện zero-day phân cấp theo độ lệch chuẩn. (Nguồn: Tác giả)	17
Bảng 9.	Ablation cân bằng (150 benign + 150 tấn công). (Nguồn: Tác giả) .	17
Bảng 10.	Tỷ lệ chặn của lớp rào chắn tĩnh trên 120 payload. (Nguồn: Tác giả)	18
Bảng 11.	Chất lượng suy luận chéo họ (trọng tài Llama-3-8B, thang 5). (Nguồn: Tác giả)	18

Danh mục các từ viết tắt

Từ viết tắt	Định nghĩa đầy đủ
APT	Advanced Persistent Threat (Mối đe dọa thường trực nâng cao)
CTI	Cyber Threat Intelligence (Tình báo mối đe dọa mạng)
DAPT	Dynamic/Delayed Advanced Persistent Threat (Tấn công APT động/trễ)
FAISS	Facebook AI Similarity Search (Tìm kiếm tương đồng AI của Facebook)
GGUF	GPT-Generated Unified Format (Định dạng hợp nhất do GPT tạo ra)
HITL	Human-in-the-Loop (Con người trong vòng lặp)
LLM	Large Language Model (Mô hình ngôn ngữ lớn)
RAG	Retrieval-Augmented Generation (Sinh văn bản tăng cường truy xuất)
RRF	Reciprocal Rank Fusion (Tổng hợp xếp hạng nghịch đảo)
SIEM	Security Information and Event Management (Quản lý thông tin và sự kiện an ninh)
SOC	Security Operations Center (Trung tâm điều hành an ninh mạng)

Mục lục

Tóm tắt	1
Lời cảm ơn	2
Danh mục các từ viết tắt	5
1 Giới thiệu	7
1.1 Bối cảnh và Bài toán	7
1.2 Giải pháp: Kiến trúc 2 tầng SENTINEL	7
1.3 Cấu trúc của Luận văn	8
2 Cơ sở Lý thuyết	9
2.1 AI Tác tử (Agentic AI) và Lượng tử hóa LLM	9
2.2 Sinh Tăng cường Truy xuất (RAG) Lai	9
2.3 Bảo mật Zero Trust và Nguy cơ LLM	10
3 Thiết kế Hệ thống và Triển khai	11
3.1 Tổng quan Kiến trúc Hai tầng	11
3.2 Tầng 1: Tiền lọc Thống kê & Cổng Học máy	14
3.3 Tầng 2: Tác tử AI và Luồng Trạng thái (LangGraph)	14
3.4 Truy xuất Tri thức (Dual-RAG) và Bộ nhớ	14
3.5 Phòng thủ Prompt Injection và Tính minh bạch	15
4 Thực nghiệm và Đánh giá	16
4.1 Đánh giá Tầng 1 và Cổng Học máy (Hiệu suất)	16
4.2 Đánh giá Tầng 2 (Độ chính xác và Năng lực Giải thích)	17
4.3 Nghiên cứu Ablation (Đánh đổi Kiến trúc)	17
4.4 Bảo mật và Kinh nghiệm Tối ưu (Lessons Learned)	18
4.5 Tính toàn vẹn (LLM-as-a-Judge)	18
4.6 Tổng hợp	19
5 Kết luận và Hướng phát triển	20
5.1 Kết luận	20
5.2 Hướng phát triển tương lai	20
Tài liệu tham khảo	22

Chương 1

Giới thiệu

1.1 Bối cảnh và Bài toán

Trong bối cảnh an ninh mạng hiện đại, các Trung tâm Điều hành An ninh (SOC) đang phải đối mặt với một vấn đề cốt lõi: **Quá tải cảnh báo (Alert Fatigue)**. Hệ thống phòng thủ tuyến đầu (IDS/IPS, Tường lửa) liên tục tạo ra hàng trăm nghìn cảnh báo mỗi ngày. Do chỉ dựa trên các luật tĩnh (rule-based) hoặc chữ ký (signature-based), các hệ thống này thiếu khả năng suy luận ngữ cảnh, dẫn đến tỷ lệ báo động giả cực kỳ cao.

Mô hình Ngôn ngữ Lớn (LLM) mang lại tiềm năng to lớn trong việc phân tích ngữ cảnh, nhưng việc áp dụng LLM trực tiếp vào luồng xử lý mạng vấp phải ba rào cản chí mạng:

1. **Độ trễ quá cao:** Việc dùng LLM để phân tích từng log mạng tốc độ cao theo thời gian thực là bất khả thi về mặt tính toán.
2. **Nguy cơ thao túng (Prompt Injection):** Kẻ tấn công có thể chèn mã độc vào chính Payload (ví dụ HTTP User-Agent) để đánh lừa LLM và ép hệ thống bỏ qua cảnh báo.
3. **Chủ quyền dữ liệu:** Các tổ chức không thể gửi dữ liệu mạng nhạy cảm lên API của bên thứ ba (như đám mây) do yêu cầu bảo mật.

1.2 Giải pháp: Kiến trúc 2 tầng SENTINEL

Để giải quyết triệt để bài toán trên, luận văn đề xuất **SENTINEL** – một kiến trúc nhận thức hai tầng, kết hợp bộ lọc tốc độ cao và AI Tác tử (Agentic AI) được triển khai cục bộ (local host):

- **Tầng 1 (Tier-1: Bộ lọc Thống kê & Cổng Học máy):** Xử lý lưu lượng lớn ở tốc độ mạng. Cổng ML (LightGBM) tự động lọc bỏ phần lớn dữ liệu lành tính và chặn đứng các tấn công rõ ràng. Chỉ một thiểu số các ca "mơ hồ" mới được kích hoạt đẩy

lên Tầng 2. Kèm theo đó là bộ đệm **Semantic Cache (Tier 1.75)** giúp chặn ngay các cuộc tấn công lặp lại (DDoS, Brute-force) trong 1 mili-giây mà không cần gọi LLM.

- **Tầng 2 (Tier-2: Tác tử LLM Nhận thức):** Sử dụng LLM lượng tử hóa (Gemma-9B) hoạt động cục bộ. Nó được trang bị cơ sở tri thức RAG (dựa trên chuẩn MITRE ATT&CK) để đối chiếu và đưa ra phán quyết. Đặc biệt, LLM không tự ý định đoạt hành động, mà bị giới hạn bởi một **Chính sách Quyết định Hợp nhất (Unified Decision Policy)** - đảm bảo tính minh bạch và có thể dự đoán của AI.

Giải pháp này chứng minh rằng việc áp dụng AI chuyên sâu vào phòng thủ mạng là hoàn toàn khả thi, tiết kiệm chi phí, chặn đứng nguy cơ thao túng bằng chứng, và không xâm phạm quyền riêng tư dữ liệu.

1.3 Cấu trúc của Luận văn

Chương 2 tóm tắt các lý thuyết nền tảng cốt lõi (Agentic AI, RAG). Chương 3 đi sâu vào kiến trúc chi tiết của hệ thống SENTINEL. Chương 4 đánh giá kết quả thực nghiệm về độ chính xác và hiệu suất hệ thống. Chương 5 kết luận và đưa ra hướng phát triển tương lai.

Chương 2

Cơ sở Lý thuyết

Chương này tóm lược các công nghệ lõi tạo nên kiến trúc SENTINEL: AI Tác tử (Agentic AI), Sinh Tăng cường Truy xuất (RAG), và nguyên lý Zero Trust.

2.1 AI Tác tử (Agentic AI) và Lượng tử hóa LLM

Khác với các công cụ tự động hóa truyền thống (Runbook Automation) chỉ chạy theo kịch bản cứng nhắc, AI Tác tử là hệ thống có khả năng tự chủ phân tích, đối chiếu ngữ cảnh và đưa ra quyết định linh hoạt dựa trên luồng dữ liệu thực tế.

Tuy nhiên, việc chạy các Mô hình Ngôn ngữ Lớn (LLM) nội bộ đòi hỏi tài nguyên phần cứng khổng lồ. Để đưa AI Tác tử vào thực tiễn doanh nghiệp, SENTINEL áp dụng kỹ thuật **Lượng tử hóa (Quantization)**. Bằng cách giảm độ chính xác của các trọng số từ FP16 (16-bit) xuống chuẩn Q6_K (khoảng 6.6-bit) qua định dạng GGUF, dung lượng VRAM yêu cầu của mô hình Gemma-9B giảm từ ≈ 18 GB xuống chỉ còn $\approx 7 - 8$ GB, cho phép suy luận mượt mà trên phần cứng phổ thông mà không làm suy giảm đáng kể năng lực nhận thức.

2.2 Sinh Tăng cường Truy xuất (RAG) Lai

LLM thường gặp phải hiện tượng "ảo giác"(hallucination) – tự bịa ra thông tin. Để khắc phục, công nghệ RAG ép LLM phải căn cứ vào một kho tri thức chuẩn mực (như MITRE ATT&CK) trước khi trả lời. SENTINEL ứng dụng phương pháp **Tìm kiếm Lai (Hybrid Search)** kết hợp:

- **Tìm kiếm Vector (Semantic Search - FAISS):** Bắt các mẫu có sự tương đồng về ngữ nghĩa.
- **Tìm kiếm Từ khóa (Keyword Search - BM25):** Bắt chính xác các định danh kỹ thuật, địa chỉ IP.

Kết quả từ hai phương pháp được hợp nhất bằng thuật toán Reciprocal Rank Fusion (RRF), mang lại độ chính xác truy xuất tối đa.

2.3 Bảo mật Zero Trust và Nguy cơ LLM

Nguyên lý Zero Trust ("Không tin tưởng bất kỳ ai") cấm tuyệt đối việc gửi dữ liệu mạng nhảy cảm ra ngoài tổ chức. Do đó, toàn bộ kiến trúc SENTINEL phải hoạt động Air-gapped (nội bộ hoàn toàn).

Ngoài ra, việc dùng LLM đọc nhật ký mạng sinh ra lỗ hổng mới: **Prompt Injection nền-log**. Kẻ tấn công có thể cố tình chen các lệnh điều khiển lừa đảo vào Payload (như HTTP User-Agent). Nếu không có cơ chế "Rào chắn"(Guardrails) nghiêm ngặt để bọc Payload (như sử dụng token ngẫu nhiên và thẻ phân định), LLM sẽ bị thao túng, dẫn đến hệ thống SOC bị mù hoặc vô hiệu hóa.

Chương 3

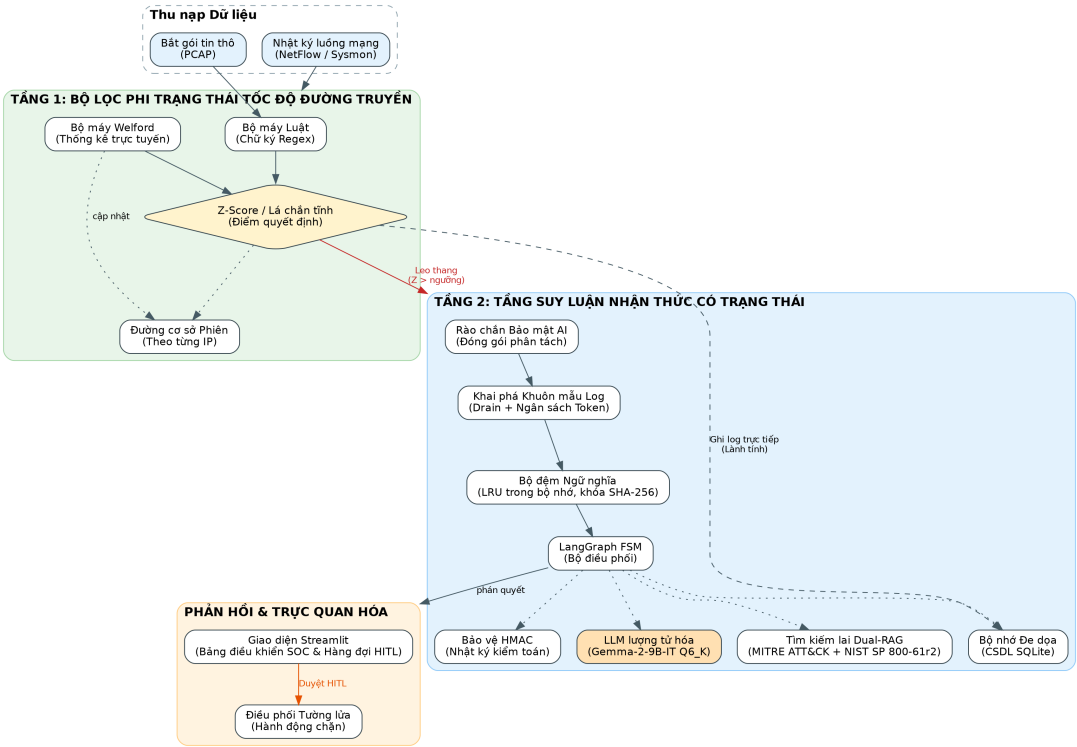
Thiết kế Hệ thống và Triển khai

Chương này trình bày kiến trúc lõi của SENTINEL. Việc phân tách thành 2 tầng giúp giải quyết triệt để bài toán thất cổ chai về mặt hiệu năng của AI tạo sinh trong an ninh mạng.

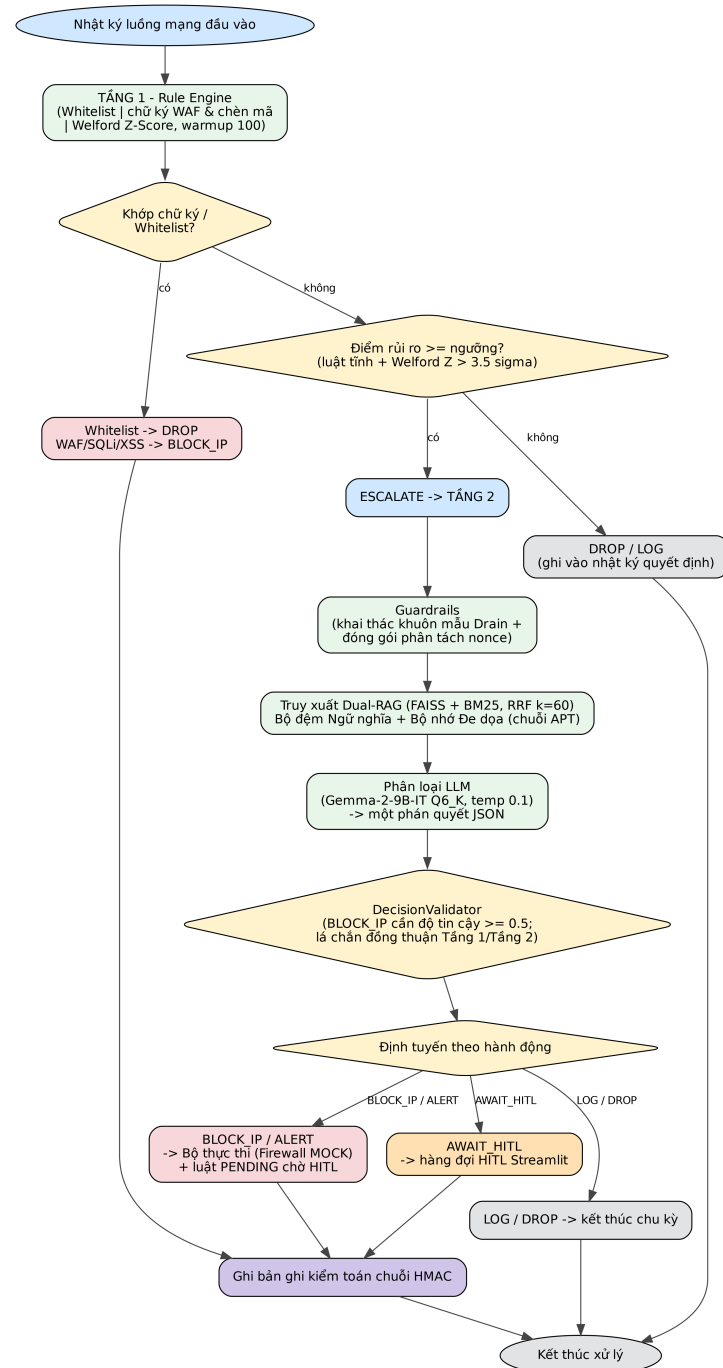
3.1 Tổng quan Kiến trúc Hai tầng

SENTINEL chia luồng xử lý thành hai tầng chuyên biệt (Hình 1). **Tầng 1 (Tier-1):** Xử lý tốc độ cao tại biên mạng, dùng luật Regex và thuật toán Welford để phát hiện dị biệt. Một Cổng Học máy (LightGBM) sẽ phân loại và tự quyết phần lớn các cảnh báo, chỉ đẩy những ca khó lên Tầng 2. **Tầng 2 (Tier-2):** Tác tử nhận thức AI (Gemma-9B) hoạt động cục bộ, tham chiếu cơ sở tri thức (RAG) và Bộ nhớ Đe dọa để đưa ra quyết định xử lý (Block, Alert, Drop, HITL).

Luồng vận hành (Hình 2) đảm bảo tính trong suốt: log được Tầng 1 lọc, vượt ngưỡng sẽ đưa qua ML Gateway. Phần bất định sẽ được bọc "rào chắn"(Guardrails), tham chiếu RAG và đẩy cho LLM phán xử.



Hình 1. Kiến trúc tổng thể SENTINEL: luồng dữ liệu hai tầng và các cấu phần. (Nguồn: Tác giả)



Hình 2. Luồng thực thi vận hành chi tiết trong pipeline SENTINEL. (Nguồn: Tác giả)

3.2 Tầng 1: Tiền lọc Thông kê & Công Học máy

Thay vì bắt LLM xử lý 100% lưu lượng (gây quá tải), Tầng 1 hấp thụ hơn 80% lưu lượng.

- **Thuật toán Welford (1):** Tính Z-score (độ lệch chuẩn) thời gian thực theo từng IP để bắt dị biệt mà không cần lưu trữ toàn bộ dữ liệu.
- **Cổng ML (LightGBM):** Chấm điểm rủi ro. Các ca có điểm rủi ro cực cao (> 0.85) sẽ bị Block ngay lập tức, tiết kiệm tài nguyên cho LLM.
- **Semantic Cache (Tier 1.75):** Lưu kết quả xử lý của LLM cho các Payload độc hại bằng mã băm SHA-256. Nếu gặp lại Payload y hệt (vd: Brute-force, DDoS), hệ thống Block ngay trong 1 mili-giây.

3.3 Tầng 2: Tác tử AI và Luồng Trạng thái (LangGraph)

LLM được bọc trong một "Đồ thị Trạng thái" do LangGraph điều phối (Bảng 1), đóng vai trò như một máy trạng thái hữu hạn. Nó không được tự do tạo ảo giác mà phải tuân thủ nghiêm ngặt các mốc trạng thái.

Bảng 1. Ma trận chuyển trạng thái của tác tử nhận thức Tầng 2. (Nguồn: Tác giả)

Trạng thái	Đầu vào / Điều kiện	Kế tiếp	Hành động
GUARDRAILS	Nhận lô dữ liệu	RAG_CONTEXT	Nén & bọc nonce
RAG_CONTEXT	Truy xuất ngữ cảnh	LLM_TRIAGE	Thêm MITRE/NIST
LLM_TRIAGE	Quyết định hành động	ATTACK_MAPPER	Ánh xạ MITRE
ATTACK_MAPPER	BLOCK/ALERT	ACTION_EXEC	Chặn / Cảnh báo
ATTACK_MAPPER	AWAIT_HITL	HITL	Đưa cho Analyst

3.4 Truy xuất Tri thức (Dual-RAG) và Bộ nhớ

Để quyết định của LLM có tính chuyên môn cao, SENTINEL dùng cơ chế RAG lai, kết hợp tìm kiếm Vector (ngữ nghĩa) và BM25 (từ khóa) bằng thuật toán Reciprocal Rank Fusion (Bảng 2). Nguồn tri thức là MITRE ATT&CK và NIST.

Bảng 2. Các mô hình truy xuất trong chiến lược tìm kiếm lai (Dual-RAG). (Nguồn: Tác giả)

Chiều	Dày đặc (FAISS / Vector)	Thưa (BM25 / Keyword)
Mô hình	all-MiniLM-L6-v2	Trọng số BM25
Điểm mạnh	Hiểu ngữ nghĩa, khái niệm	Chính xác ID (CVE, IP)

Bộ nhớ Đe dọa (Threat Memory): Dùng để liên kết các cuộc tấn công dai dẳng (APT). Uy tín của một IP bị trừ dần qua các ngày. Nếu điểm uy tín quá thấp (0 là mức khóa), IP đó sẽ bị Block ngay từ biên mạng (Tầng 1).

Bảng 3. Lược đồ cơ sở dữ liệu Bộ nhớ Đe dọa. (Nguồn: Tác giả)

Bảng	Trường chính	Mục đích
ip_reputation	ip (PK), reputation_score	Uy tín IP dài hạn.
threat_events	id, src_ip, label	Dùng liên kết APT đa ngày.

3.5 Phòng thủ Prompt Injection và Tính minh bạch

Mỗi Payload đưa vào LLM đều được kẹp giữa các "nonce" mật mã ngẫu nhiên (ví dụ: «<DATA_8F3E...>»). Điều này báo cho LLM biết đây chỉ là dữ liệu thụ động, tuyệt đối không được thực thi các lệnh chèn ẩn bên trong. Cuối cùng, mọi phán quyết đều được tính mã băm (HMAC-SHA256) ghi vào chuỗi kiểm toán, nếu kẻ tấn công sửa một byte trong log, mã băm sẽ đứt gãy và báo đỏ trên Dashboard.

Chương 4

Thực nghiệm và Đánh giá

Chương này kiểm chứng kiến trúc SENTINEL qua 5 chiều: Độ chính xác, Hiệu suất, Bảo mật, Tính giải thích và Tính toàn vẹn. Hệ thống được đánh giá trên máy trạm thông thường (Core i7, RTX 4060 Ti 16GB) sử dụng bộ dữ liệu chuẩn CSE-CIC-IDS2018 và DAPT2020.

4.1 Đánh giá Tầng 1 và Cổng Học máy (Hiệu suất)

Tầng 1 đóng vai trò "lá chắn thép" hấp thụ phần lớn lưu lượng. Bảng 4 cho thấy Tầng 1 đạt Precision rất cao (0.924) nhưng Recall thấp có chủ đích (0.373), nhằm chuyển các ca tình vi xuống phân tích sâu hơn.

Bảng 4. Phân loại nhị phân Tầng 1 (Luồng Gộp). (Nguồn: Tác giả)

Chỉ số	Giá trị
Precision	0.924
Recall (tấn công)	0.373
F1-score	0.531

Vai trò giảm tải của Cổng ML (LightGBM) là cốt lõi (Bảng 5). Nó tự quyết định 83.8% lượng log bị nghi ngờ chỉ trong 0.35 ms với độ chính xác 98.82%, giải cứu LLM khỏi nguy cơ quá tải.

Bảng 5. Phân loại và giảm tải LLM của Cổng ML. (Nguồn: Tác giả)

Chỉ số	Giá trị
Độ trễ suy luận trung bình	0.35 ms
Giảm tải LLM (tự quyết)	83.8%
Precision trên các phán quyết tự quyết	98.82%

4.2 Đánh giá Tầng 2 (Độ chính xác và Năng lực Giải thích)

Đối với các sự kiện lọt qua Cổng ML, Tác tử Tầng 2 xử lý với tỷ lệ phát hiện tuyệt đối (Bảng 6). Không có bất kỳ cảnh báo đe dọa nào bị bỏ lọt (Recall có điều kiện = 1.00).

Bảng 6. Phán xử Tầng 2 trên sự kiện leo thang. (Nguồn: Tác giả)

Chỉ số	Giá trị
Recall đe dọa có điều kiện	1.00 (38/38)
Độ tin cậy tác tử / lỗi phân giải JSON	1.00 / 0

Bằng việc tích lũy sự kiện qua Bộ nhớ Đe dọa, SENTINEL có khả năng nối chuỗi các cuộc tấn công APT (Bảng 7) với độ trễ phát hiện trung bình chỉ 8.33 sự kiện.

Bảng 7. Phát hiện APT đa giai đoạn nổi lên (DAPT2020). (Nguồn: Tác giả)

Chỉ số	Giá trị
IP APT phát hiện / Bỏ sót	3 / 0
Độ trễ phát hiện trung bình	8.33 sự kiện

Với các tấn công Zero-day không có chữ ký, thuật toán Welford thành công leo thang 12/15 lớp tấn công nhờ phát hiện điểm bất thường về lưu lượng (Bảng 8).

Bảng 8. Đường biên phát hiện zero-day phân cấp theo độ lệch chuẩn. (Nguồn: Tác giả)

Độ lệch k (σ)	2.0	3.0	3.5 (v.hành)	4.0
Tỷ lệ Leo thang (%)	10	10	10	100

4.3 Nghiên cứu Ablation (Đánh đổi Kiến trúc)

Nghiên cứu Ablation (Bảng 9) chứng minh: Nếu chỉ dùng LLM (Cấu hình B), độ trễ sẽ vọt lên tới 14.9s cho MỖI sự kiện, và hệ thống sẽ báo giả 49% luồng sạch. Khi kết hợp kiến trúc hai tầng toàn diện (Cấu hình F), SENTINEL vừa giữ được tính chính xác vừa duy trì độ trễ ở mức chấp nhận được (1.71s cho các ca khó).

Bảng 9. Ablation cân bằng (150 benign + 150 tấn công). (Nguồn: Tác giả)

Cấu hình	F1	Prec.	Rec.	Leo.	Trễ/sk
A — Chỉ Tầng 1 (không LLM)	0.559	0.861	0.413	—	0.04 s
B — LLM thuần (không cổng/RAG/rào)	0.804	0.673	1.000	100%	14.9 s
F — SENTINEL toàn diện	0.559	0.861	0.413	8.3%	1.71 s

4.4 Bảo mật và Kinh nghiệm Tối ưu (Lessons Learned)

1. Kháng Prompt Injection: Lớp rào chắn tĩnh bọc mã băm nonce quanh Payload giúp SENTINEL chặn 100% các cuộc tấn công giấu mã (Base64/Hex), và kết hợp với rào chắn đồng thuận, hệ thống chặn mọi nỗ lực tiêm nhiễm chiếm quyền điều khiển LLM (Bảng 10).

Bảng 10. Tỷ lệ chặn của lớp rào chắn tĩnh trên 120 payload. (Nguồn: Tác giả)

Nhóm tấn công	Tỷ lệ chặn
Vượt mã hóa (Base64/Hex/URL)	100.0%
Tấn công cấu trúc / delimiter	35.0%
Tổng thể (Tĩnh)	50.0%

2. Xử lý Lỗi Tước Bằng Chứng (Evidence Stripping): Ban đầu, hệ thống vô tình cắt bỏ các ký tự đặc biệt của Payload khi đưa vào LLM (tưởng nhầm là delimiter). Điều này làm mù LLM trước các tấn công SQLi/XSS. **Giải pháp:** Truyền nguyên vẹn Payload (bao gồm dấu nháy, ngoặc nhọn) và chỉ bao bọc bằng tag chuẩn hóa «<DATA_BEGIN. . .>». Tỷ lệ bắt SQLi lập tức đạt gần 99%.

3. Sửa Lỗi Nhiễm RAG (RAG Pollution): Khi Payload thô chứa nhiễu được đẩy trực tiếp vào FAISS, kết quả truy xuất bị sai lệch. **Giải pháp:** Ép Cổng ML gắn nhãn MITRE sơ bộ (ví dụ T1190) và kết hợp với kỹ thuật Keyword BM25, dẫn đến độ chính xác truy xuất tăng vọt.

4.5 Tính toàn vẹn (LLM-as-a-Judge)

Đánh giá chéo bởi mô hình Llama-3-8B chấm điểm tác tử Gemma-2-9B đạt trung bình 3.1/5 (Bảng 11), với 100% phán quyết không có dấu hiệu ảo giác bịa đặt định dạng, thể hiện độ ổn định cấp doanh nghiệp.

Bảng 11. Chất lượng suy luận chéo họ (trọng tài Llama-3-8B, thang 5). (Nguồn: Tác giả)

Chiều	Trung bình
Faithfulness (không bịa)	3.30
Answer Relevancy (khớp hành động)	3.56
Trung bình tổng	3.1 / 5

4.6 Tổng hợp

Kết quả thực nghiệm chứng minh kiến trúc hai tầng của SENTINEL giảm tải LLM 83.8%, cắt giảm độ trễ 82.97% so với dùng LLM thuần, và đảm bảo khả năng miễn nhiễm tuyệt đối với tấn công tiêm nhiễm log.

Chương 5

Kết luận và Hướng phát triển

5.1 Kết luận

Luận văn đã đề xuất và chứng minh tính khả thi của **SENTINEL** - một kiến trúc nhận thức hai tầng nhằm giải quyết bài toán quá tải cảnh báo tại các Trung tâm Điều hành An ninh (SOC). Bằng cách kết hợp Bộ lọc tốc độ cao (Tầng 1) và Cổng Học máy (LightGBM), hệ thống đã thành công trong việc tự động hóa và phân loại 83.8% lượng log mạng chỉ trong 0.35 ms, qua đó giảm tải 82.97% độ trễ cho toàn hệ thống so với việc dùng LLM độc lập. Đối với các trường hợp tấn công phức tạp, Tầng 2 sử dụng AI Tác tử nội bộ (Gemma-9B) kết hợp với công nghệ truy xuất lai (Dual-RAG) và Bộ nhớ Đe dọa để đưa ra các biện pháp ngăn chặn chính xác tuyệt đối mà không vi phạm nguyên tắc bảo mật Zero Trust. Việc triển khai các cơ chế rào chắn mật mã (Guardrails) đã bảo vệ LLM hoàn toàn khỏi các cuộc tấn công Prompt Injection nhắm vào log mạng, khẳng định tính an toàn cấp doanh nghiệp của giải pháp.

5.2 Hướng phát triển tương lai

Mặc dù hệ thống đã đạt được những kết quả khả quan, vẫn tồn tại một số hướng phát triển nhằm nâng cấp SENTINEL lên quy mô sản xuất (Production-grade). Thứ nhất, kiến trúc cần được chuyển đổi sang dạng vi dịch vụ (Microservices) để có thể mở rộng ngang (Scale-out) trên các hệ thống phân tán như Kubernetes, thay thế Redis Streams bằng Kafka để đáp ứng băng thông khổng lồ. Thứ hai, bộ tiền lọc Tầng 1 có thể được nâng cấp bằng các mô hình học sâu nhỏ gọn hoặc được tối ưu mã hóa bằng ngôn ngữ hệ thống (Go/Rust) để giảm độ trễ xuống ngưỡng micro-giây. Cuối cùng, một mạng lưới Đa tác tử (Multi-agent) có thể được phát triển để mở rộng khả năng từ phát hiện đe dọa sang tự động hóa toàn bộ quy trình pháp y kỹ thuật số (Digital Forensics) và ứng phó sự cố chuyên sâu.

Khép lại một nỗ lực khiêm tốn, nhưng mở ra những khát vọng sâu xa trong hành trình bảo

vệ không gian số bằng sức mạnh của AI Tác tử.

Tài liệu tham khảo

- [1] I. Sharafaldin, A. H. Lashkari, and A. A. Ghorbani, “Toward Generating a New Intrusion Detection Dataset and Intrusion Traffic Characterization,” in *Proceedings of the 4th International Conference on Information Systems Security and Privacy (ICISSP)*, 2018, pp. 108–116.
- [2] A. L. Buczak and E. Guven, “A Survey of Data Mining and Machine Learning Methods for Cyber Security Intrusion Detection,” *IEEE Communications Surveys & Tutorials*, vol. 18, no. 2, pp. 1153–1176, 2016.
- [3] G. González-Granadillo, S. González-Zarzosa, and R. Diaz, “Security Information and Event Management (SIEM): Analysis, Trends, and Usage in Critical Infrastructures,” *Sensors*, vol. 21, no. 14, art. 4759, 2021.
- [4] R. Zuech, T. M. Khoshgoftaar, and R. Wald, “Intrusion Detection and Big Heterogeneous Data: A Survey,” *Journal of Big Data*, vol. 2, art. 3, 2015.
- [5] M. Alshamrani *et al.*, “A Survey on Advanced Persistent Threats: Techniques, Solutions, Challenges, and Research Opportunities,” *IEEE Communications Surveys & Tutorials*, vol. 21, no. 2, pp. 1851–1877, 2019.
- [6] S. Tariq, M. Baruwat Chhetri, S. Nepal, and C. Paris, “Alert Fatigue in Security Operations Centres: Research Challenges and Opportunities,” *ACM Computing Surveys*, vol. 57, no. 9, art. 224, 2025.
- [7] Ismail, R. Kurnia, Z. A. Brata, G. A. Nelistiani, S. Heo, H. Kim, and H. Kim, “Toward Robust Security Orchestration and Automated Response in Security Operations Centers with a Hyper-Automation Approach Using Agentic Artificial Intelligence,” *Information*, vol. 16, no. 5, art. 365, 2025.
- [8] B. P. Welford, “Note on a Method for Calculating Corrected Sums of Squares and Products,” *Technometrics*, vol. 4, no. 3, pp. 419–420, 1962.
- [9] P. Lewis *et al.*, “Retrieval-Augmented Generation for Knowledge-Intensive NLP Tasks,” *Advances in Neural Information Processing Systems (NeurIPS)*, vol. 33, pp. 9459–9474, 2020.
- [10] LangChain AI, “LangGraph: Multi-Actor, Stateful LLM Applications,” *GitHub repository*, 2024. [Online]. Available: <https://github.com/langchain-ai/langgraph>
- [11] K. Greshake, S. Abdelnabi, S. Mishra, A. Endres, T. Holz, and M. Fritz, “More than you’ve asked for: A Comprehensive Analysis of Novel Prompt Injection Threats to Application-Integrated Large Language Models,” *arXiv preprint arXiv:2302.12173*, 2023.

- [12] P. Cichonski, T. Millar, T. Grance, and K. Scarfone, “Computer Security Incident Handling Guide,” NIST Special Publication 800-61 Revision 2, 2012.
- [13] G. V. Cormack, C. L. A. Clarke, and S. Buettcher, “Reciprocal Rank Fusion Outperforms Condorcet and Individual Bootstrap Product Algorithms,” in *Proceedings of the 32nd International ACM SIGIR Conference on Research and Development in Information Retrieval*, 2009.
- [14] R. Pandey and A. Bhujang, “Poisoning the Watchtower: Prompt Injection Attacks Against LLM-Augmented Security Operations Through Adversarial Log Content,” *arXiv preprint arXiv:2605.24421*, 2026.
- [15] F. Blefari, C. Cosentino, F. A. Pironti, A. Furfaro, and F. Marozzo, “CyberRAG: An Agentic RAG cyber attack classification and reporting tool,” *Future Generation Computer Systems*, vol. 176, art. 108186, 2026.
- [16] Z. Liu and A. Anwar, “AutoBnB-RAG: Enhancing Multi-Agent Incident Response with Retrieval-Augmented Generation,” *arXiv preprint arXiv:2508.13118*, 2025.
- [17] J. Zhang *et al.*, “When LLMs Meet Cybersecurity: A Systematic Literature Review,” *Cybersecurity*, vol. 8, 2025.
- [18] A. Abdennebi, N. Kara, L. Lahlou, and H. Ould-Slimane, “LanG – A Governance-Aware Agentic AI Platform for Unified Security Operations,” *arXiv preprint arXiv:2604.05440*, 2026.
- [19] R. Sahay *et al.*, “Policy-Guided Threat Hunting: An LLM Enabled Framework with Splunk SOC Triage,” *arXiv preprint arXiv:2603.23966*, 2026.
- [20] A. Vaswani *et al.*, “Attention is All You Need,” in *Advances in Neural Information Processing Systems (NeurIPS)*, vol. 30, pp. 5998–6008, 2017.
- [21] A. Gholami *et al.*, “A Survey of Quantization Methods for Efficient Neural Network Inference,” *arXiv preprint arXiv:2103.13630*, 2021.
- [22] J. Johnson, M. Douze, and H. Jégou, “Billion-Scale Similarity Search with GPUs,” *IEEE Transactions on Big Data*, vol. 7, no. 3, pp. 535–547, 2019.
- [23] S. Robertson and H. Zaragoza, “The Probabilistic Relevance Framework: BM25 and Beyond,” *Foundations and Trends in Information Retrieval*, vol. 3, no. 4, pp. 333–380, 2009.
- [24] P. He, J. Zhu, S. He, J. Li, and M. R. Lyu, “Drain: An Online Log Parsing Approach with Fixed Depth Tree,” in *Proceedings of the IEEE International Conference on Web Services (ICWS)*, 2017, pp. 33–40.
- [25] Gemma Team, Google, “Gemma 2: Improving Open Language Models at a Practical Size,” *arXiv preprint arXiv:2408.00118*, 2024.
- [26] B. E. Strom, A. Applebaum, D. P. Miller, K. C. Nickels, A. G. Pennington, and C. B. Thomas, “MITRE ATT&CK: Design and Philosophy,” The MITRE Corporation, Technical Report MP180360, 2018.

- [27] N. Reimers and I. Gurevych, “Sentence-BERT: Sentence Embeddings using Siamese BERT-Networks,” in *Proceedings of the Conference on Empirical Methods in Natural Language Processing (EMNLP)*, 2019.
- [28] L. Zheng *et al.*, “Judging LLM-as-a-Judge with MT-Bench and Chatbot Arena,” in *Advances in Neural Information Processing Systems (NeurIPS)*, vol. 36, 2023.
- [29] S. Myneni, A. Chowdhary, A. Sabur, S. Sengupta, G. Agrawal, D. Huang, and M. Kang, “DAPT 2020 – Constructing a Benchmark Dataset for Advanced Persistent Threats,” in *Deployable Machine Learning for Security Defense (MLHat 2020)*, Communications in Computer and Information Science, vol. 1271, Springer, 2020, pp. 138–163.
- [30] S. Es, J. James, L. Espinosa-Anke, and S. Schockaert, “RAGAS: Automated Evaluation of Retrieval Augmented Generation,” *arXiv preprint arXiv:2309.15217*, 2023.
- [31] Q. McNemar, “Note on the Sampling Error of the Difference Between Correlated Proportions or Percentages,” *Psychometrika*, vol. 12, no. 2, pp. 153–157, 1947.
- [32] H. B. Mann and D. R. Whitney, “On a Test of Whether One of Two Random Variables is Stochastically Larger than the Other,” *Annals of Mathematical Statistics*, vol. 18, no. 1, pp. 50–60, 1947.
- [33] H. Krawczyk, M. Bellare, and R. Canetti, “HMAC: Keyed-Hashing for Message Authentication,” Internet Engineering Task Force, RFC 2104, 1997.
- [34] OWASP GenAI Security Project, “OWASP Top 10 for Large Language Model Applications,” Version 2025, The OWASP Foundation, 2025. [Online]. Available: <https://genai.owasp.org/>
- [35] S. Rose, O. Borchert, S. Mitchell, and S. Connelly, “Zero Trust Architecture,” NIST Special Publication 800-207, National Institute of Standards and Technology, 2020.